PROPOSAL KARYA (UX CASE STUDY)

GARDA TECH NATIONAL INNOVATION COMPETITION (GTNIC) 2026

KATEGORI: AI Agent Development

Sub-Tema: "Building Intelligent AI Agents for Enterprise Productivity"

JUDUL KARYA / APLIKASI WEB:

GTNIC SOAR

Disusun Oleh Tim:

HackWithGoh

1. Marcelinus Wijaya Oey - Bina Nusantara
2. Greshen Chin - Bina Nusantara
3. Melvin Goh - Bina Nusantara

1. LATAR BELAKANG MASALAH

1.1 Krisis Keamanan Siber di Lingkungan Enterprise

Transformasi digital di sektor enterprise, perbankan, telekomunikasi, dan layanan publik meningkatkan efisiensi, tetapi juga memperbesar ketergantungan pada infrastruktur digital. Risiko tersebut terlihat pada serangan ransomware Brain Cipher terhadap Pusat Data Nasional Sementara (PDNS) 2 pada Juni 2024. Insiden berdampak pada 239 instansi pemerintah dan 282 tenant. Pemerintah mengidentifikasi ransomware tersebut sebagai pengembangan LockBit 3.0, dengan tuntutan tebusan USD 8 juta. Peristiwa ini menegaskan pentingnya pemantauan keamanan, pencadangan data, serta deteksi dan respons insiden yang terkoordinasi [7][9].

1.2 Ancaman Siber dan Dampak Finansial

Laporan Ancaman Digital di Indonesia Semester I 2026 dari AwanPintar.id, sebagaimana diberitakan Kompas.com, mencatat 257.976.333 aktivitas serangan siber selama Januari–Juni 2026, rata-rata sekitar 16 aktivitas per detik. Jumlah tersebut meningkat 93,33% dibandingkan periode yang sama tahun sebelumnya. Kategori dominan adalah Attempted Administrator Privilege Gain (43,65%), yaitu percobaan memperoleh hak akses administrator [1].

IBM Security (2024) melaporkan rata-rata biaya kebocoran data global sebesar USD 4,88 juta. Sebanyak 70% organisasi yang mengalami kebocoran data menyatakan insiden mengganggu operasional secara signifikan atau sangat signifikan. Organisasi yang menggunakan AI dan otomatisasi secara ekstensif dapat mengidentifikasi serta menangani insiden rata-rata 98 hari lebih cepat. Pada alur kerja pencegahan, penggunaan AI secara ekstensif berkaitan dengan biaya kebocoran rata-rata USD 2,2 juta lebih rendah [2].

1.3 Hambatan SOC dan Kebutuhan Solusi

SOC enterprise menghadapi defisit tenaga profesional keamanan siber yang diperkirakan mencapai 4,8 juta orang secara global [3]. Analis juga harus memantau,

menyelidiki, dan memverifikasi alert secara berkelanjutan. Chatbot AI berbasis teks belum tentu mampu menjalankan investigasi melalui tools forensik secara langsung.

2. TUJUAN, MANFAAT, DAN SOLUSI

2.1 Tujuan Pengembangan

1. Otomasi investigasi multi-tool: mengembangkan agen AI menggunakan Gemini 3.8 Flash pada Google Cloud Vertex AI, dengan penalaran mandiri dan hingga tiga putaran investigasi berantai.
2. Validasi klaim: menerapkan Claim Guard deterministik untuk memeriksa kesesuaian klaim AI dengan fakta hasil eksekusi tools. Klaim tanpa bukti pendukung ditandai dan tidak ditampilkan sebagai fakta terkonfirmasi.
3. Percepatan triase: mengotomasi triase awal dan investigasi dengan waktu pemrosesan 3,5–7 detik per tiket berdasarkan pengujian internal pada lingkungan simulasi.
4. Tata kelola Human-in-the-Loop: menyediakan dasbor SOC yang menampilkan Attack Story, bukti Pro vs Contra, taksonomi MITRE ATT&CK, dan persetujuan mitigasi oleh analis.

2.2 Manfaat Solusi

- Enterprise: membantu mempercepat triase dan investigasi, mendukung pemantauan berkelanjutan, serta menyediakan jejak audit yang dapat ditinjau. IBM melaporkan hubungan penggunaan AI secara ekstensif pada alur pencegahan dengan biaya kebocoran rata-rata USD 2,2 juta lebih rendah [2].
- Analis SOC: mengurangi pekerjaan investigasi repetitif melalui pengumpulan bukti, analisis alert, dan penyusunan laporan otomatis; analis tetap dapat meninjau bukti pendukung maupun kontradiktif.
- Pimpinan/CISO: menyediakan visibilitas ancaman dan audit trail forensik untuk mendukung akuntabilitas pengambilan keputusan.

2.3 Solusi Teknologi

GTNIC SOAR mengintegrasikan: (1) ingest telemetri Nginx reverse proxy pada lab OWASP Juice Shop dan log Wazuh SIEM dengan deduplikasi per IP dan rule ID; (2) penalaran Gemini 3.8 Flash yang memanggil empat tools forensik; (3) verifikasi Claim Guard terhadap fakta; (4) matriks bukti Pro vs Contra; dan (5) dasbor persetujuan mitigasi oleh analis manusia.

Empat tools investigasi: search_alerts_by_ip, get_login_history, inspect_web_attack, dan mitre_owasp_rag.

3. TARGET PENGGUNA / PASAR APLIKASI

3.1 Segmen Target

Target utama GTNIC SOAR adalah fintech, e-commerce, bank digital, dan penyedia Managed Security Service Provider (MSSP) lokal yang menghadapi ancaman siber serta kebutuhan perlindungan data, tetapi memiliki keterbatasan analis keamanan. Segmen sekunder meliputi perusahaan menengah pengguna Wazuh, BUMD, rumah sakit, dan perguruan tinggi. Sistem dibangun di atas Wazuh open-source. Target awal 8–10 organisasi pilot merupakan asumsi tim dan perlu divalidasi melalui tahap pilot.

3.2 Profil Pengguna

Persona	**Masalah utama**	**Kebutuhan**	**Dukungan GTNIC SOAR**
SOC Analyst Tier-1	Alert fatigue; risiko melewatkan ancaman saat menyaring alert.	Triase cepat dan pemilahan false positive berbasis bukti.	Triase otomatis dan ringkasan investigasi.
Incident Responder	Waktu tersita untuk mengumpulkan	Bukti forensik terstruktur,	Riwayat IP, payload, dan taktik tersaji dalam

	dan mengorelasikan log secara manual.	payload, dan pemetaan MITRE.	matriks Pro–Contra.
CISO	Biaya operasional SOC dan keterbatasan talenta; kebutuhan audit insiden.	Visibilitas, efisiensi, dan jejak keputusan.	Audit trail dan catatan persetujuan analis.

Persona di atas merupakan gambaran kebutuhan pengguna yang dituju, bukan hasil survei pengguna.

3.3 ALUR KERJA: SEBELUM VS SESUDAH

Tahap	**Proses manual (estimasi tim)**	**Dengan GTNIC SOAR**
Pengumpulan bukti	Mencari riwayat IP di Wazuh (±10 menit).	Empat tools forensik otomatis (±3–5 detik).
Analisis MITRE/OWASP	Pencarian manual melalui browser (±8 menit).	Pencarian vektor pgvector (±1 detik).
Sintesis dan tindakan	Menulis laporan manual (±7 menit).	Attack Story dan tindakan persetujuan (±5 detik).
Total per tiket	±25–30 menit.	3,5–7 detik.

Catatan: durasi manual merupakan estimasi tim, bukan standar universal industri. Waktu GTNIC SOAR diukur pada 12 skenario uji di lab simulasi dan belum mewakili seluruh kondisi operasional SOC enterprise.

4. FITUR UTAMA & KEUNIKAN APLIKASI

4.1 Dua Belas Fitur Fungsional

1. Autonomous Multi-Tool Calling Engine: siklus ReAct melalui Gemini 3.8 Flash hingga tiga putaran investigasi.
2. search_alerts_by_ip: agregasi alert Wazuh Indexer 24 jam terakhir per IP.
3. get_login_history: analisis log autentikasi, termasuk rule 100100 (gagal) dan 100103 (berhasil), untuk investigasi brute force.
4. inspect_web_attack: parsing payload SQLi/XSS, kode respons HTTP, serta parameter Path Traversal dan Command Injection.
5. mitre_owasp_rag: pencarian kemiripan kosinus melalui pgvector untuk MITRE ATT&CK v15 dan OWASP Top 10.
6. Deterministic Claim Guard: validasi klaim terhadap evidence_ref; CONFIRMED memerlukan minimal dua bukti independen tanpa kontradiksi.
7. Bilateral Evidence Matrix: menampilkan bukti pendukung (Pro) dan meringankan/kontradiktif (Contra).
8. Deterministic Scoring Engine: menghitung skor keparahan dan keyakinan berdasarkan rule Wazuh serta bukti empiris.
9. Real-Time SOC Dashboard: dasbor Next.js 15 dengan SWR auto-polling tiga detik, metrik, dan filter.
10. Human-in-the-Loop Governance: Approve Mitigation dan Reject False Positive dengan otorisasi, waktu ISO 8601, dan audit trail.
11. Multi-Channel Alerting: notifikasi Discord melalui REST API v10 dan webhook n8n secara asinkron.
12. Live Attack Simulation Lab: OWASP Juice Shop v17 di balik Nginx untuk demonstrasi dan validasi.

4.2 BENCHMARK EVALUASI KINERJA

Perbandingan berikut merupakan hasil/estimasi yang dicantumkan tim. Pengujian GTNIC SOAR dilakukan pada 12 skenario serangan terkalibrasi di lab simulasi OWASP Juice Shop dan dataset telemetri SIEM.

Metrik	*Analis manual*	*Baseline chatbot*	*GTNIC SOAR*
Waktu triase/tiket	*20–30 menit*	*15–30 detik*	*3,5–6,8 detik*
Klaim tanpa bukti	*Tidak berlaku (manual)*	*28–42% (klaim proposal)*	*0% klaim tanpa bukti tervalidasi*
Korelasi MITRE/OWASP	*Parsial/manual*	*Parsial/statis*	*Otomatis melalui pgvector RAG*
Kapasitas triase	*2–3 tiket/jam*	*10–20 tiket (pasif)*	*400–600 tiket/jam (otonom)**
Jejak audit tools	*Manual pada tiket*	*Tidak tersedia (black box)*	*Tool trace terminal*
Bukti Pro vs Contra	*Jarang disajikan*	*Tidak tersedia*	*Tersedia*

**Kapasitas GTNIC SOAR sebagaimana dicantumkan dalam hasil uji internal. Angka ini menggambarkan skenario pengujian, bukan jaminan kapasitas pada seluruh lingkungan produksi.*

Catatan interpretasi

Waktu triase pada tabel benchmark (3,5–6,8 detik) dan alur kerja (3,5–7 detik) berasal dari penyajian hasil yang berbeda di proposal awal. Keduanya dipertahankan sesuai konteks masing-masing dan tidak digabungkan menjadi satu angka.

5. ARSITEKTUR SISTEM, SKEMA DATABASE & TEKNOLOGI

5.1 Stack Teknologi

Komponen	**Teknologi / versi**	**Peran**
AI Foundation	**Vertex AI Gemini 3.8 Flash**	**Penalaran agen dan function calling.**

Embedding	**Vertex AI text-embedding-005, 768 dimensi**	**Embedding semantik MITRE ATT&CK dan OWASP.**
Backend	**FastAPI (Python 3.11), 0.115+; Pydantic v2**	**API asinkron dan dokumentasi Swagger.**
Database	**PostgreSQL 16 + pgvector 0.7+**	**Data relasional dan pencarian vektor HNSW/cosine.**
SIEM	**Wazuh Manager & Indexer 4.9.0 / 4.8+**	**Agregasi log host dan alert jaringan.**
Lab & Proxy	**OWASP Juice Shop 17.x; Nginx 1.27-alpine**	**Target simulasi dan pencatatan lalu lintas HTTP.**
Frontend	**Next.js 15.x, React 19, TypeScript**	**Antarmuka web dan App Router.**
UI & polling	**Tailwind CSS 3.4+, Lucide, SWR 2.2+**	**Tampilan SOC dan auto-polling tiga detik.**
Notifikasi	**Discord REST API v10 dan n8n**	**Notifikasi operasional asinkron.**
DevOps	**Docker & Docker Compose 26.x**	**Orkestrasi enam kontainer modular di Google Compute Engine.**

5.2 Alur Arsitektur End-to-End

1. Persepsi: Nginx menangkap log HTTP JSON dari lab Juice Shop; Wazuh mengumpulkan log host.
2. Ingesti: FastAPI mengelompokkan alert berdasarkan IP dan rule ID.
3. Penalaran: Gemini 3.8 Flash mengevaluasi alert dan memanggil empat tools forensik dalam siklus ReAct.
4. Validasi: Claim Guard mencocokkan klaim dengan fakta (evidence_ref) dan menghitung skor deterministik.
5. Presentasi: Next.js menampilkan Attack Story, bukti Pro vs Contra, dan gerbang persetujuan Approve Mitigation.

5.3 VALIDASI KLAIM DAN SKORING DETERMINISTIK

Setiap bukti harus merujuk secara tepat pada fakta empiris hasil tools (evidence_ref $\in$ F_empiris). Bukti pro efektif dibatasi maksimal dua per tool. Status insiden ditentukan sebagai berikut:

· CONFIRMED: minimal dua bukti pro efektif dari sedikitnya dua tools independen dan tidak ada bukti kontra.
· LIKELY: terdapat sedikitnya satu bukti pro valid, tetapi syarat CONFIRMED belum terpenuhi.
· UNCERTAIN: tidak ada bukti valid atau ditemukan data yang inkonsisten.

Skor Keparahan (S)

$S = \text{clamp}(10, 100, (L_{wazuh} \times 5) + (\min(|E_{pro_eff}|, 4) \times 10) - (\min(|E_{contra}|, 4) \times 12) + \Delta_{confirmed})$

L_{wazuh} adalah level rule Wazuh (1–15); kontribusi bukti pro maksimal +40; penalti kontra maksimal −48; dan $\Delta_{confirmed} = +20$ khusus untuk status CONFIRMED. Kategori: Critical ($S \geq 80$), High ($60 \leq S < 80$), Medium ($40 \leq S < 60$), dan Low ($S < 40$).

Skor Keyakinan (C)

C = clamp(0, 100, round(100 × (0.5 × Validity + 0.5 × Coverage)) − P_inconsistent − P_claim)

Validity = |E_valid| / |E_claimed|; Coverage = min(1.0, |Tools| / 3); P_inconsistent = penalti 20 untuk anomali telemetri; P_claim = penalti 10 untuk setiap klaim tanpa bukti.

5.4 Skema Basis Data

Tabel	Mesin	Data utama
incidents	**PostgreSQL 16**	**27 atribut insiden: raw_alert, status, severity, confidence, attack_story, bukti Pro/Contra, tool_trace, decided_by, dan latency.**
security_knowledge	**pgvector HNSW**	**Taksonomi MITRE ATT&CK dan OWASP Top 10 beserta embedding 768 dimensi.**
alert_dedup	**Relasional (in-memory/disk)**	**Pelacakan deduplikasi alert per alamat IP sumber dan rule ID.**
benchmark_runs	**Relasional evaluasi**	**Hasil 12 skenario: expected vs agent verdict, evidence validity ratio, token count, dan latensi.**

6. BATASAN SISTEM APLIKASI

1. Pertahanan pasif dan persetujuan manusia: agen berada pada mode read-only untuk mitigasi. Approve Mitigation mencatat otorisasi analis dan audit trail ke database, bukan mengubah firewall secara langsung. Otomasi firewall aktif direncanakan pada Roadmap Fase 1.
2. Ruang lingkup deteksi: sensor web berfokus pada SQLi dan XSS dalam investigasi agen serta Path Traversal dan Command Injection pada ingress gateway proxy.
3. Fail-safe local triage: saat Vertex AI terputus atau kuota tercapai, sistem beralih ke Local Triage Heuristic Engine agar pemantauan dasar dan pencatatan insiden tetap berjalan.
4. Single-tenant: dasbor saat ini dioptimalkan untuk satu entitas enterprise dan belum mendukung partisi data multi-organisasi untuk MSSP besar.

Mitigasi risiko yang diterapkan

Validasi klaim dilakukan melalui Claim Guard dan rujukan evidence_ref; keputusan mitigasi tetap memerlukan persetujuan analis. Sistem juga menyediakan jejak tool dan audit trail untuk peninjauan. Batasan deteksi dan mode operasi dijelaskan di atas agar ruang lingkup kemampuan sistem tidak ditafsirkan melebihi implementasi yang dijelaskan.

7. TANGKAPAN LAYAR (SCREENSHOT) ANTARMUKA

7.1 Dashboard Website

7.2 Detail insiden

8. RENCANA PENGEMBANGAN LANJUTAN (FUTURE DEVELOPMENT)

Peta jalan pengembangan GTNIC SOAR untuk implementasi skala industri dibagi ke dalam lima fase:

- Fase 1 – Q1 2027 | Active Response Firewall Automation: integrasi Approve Mitigation dengan Cloudflare WAF, AWS Security Group, dan Wazuh Active Response untuk isolasi IP otomatis.
- Fase 2 – Q2 2027 | Threat Intelligence Enrichment: integrasi API VirusTotal, AbuseIPDB, Shodan, dan AlienVault OTX untuk verifikasi reputasi ancaman global.
- Fase 3 – Q3 2027 | Automated Compliance PDF Report: generator laporan kepatuhan UU PDP Pasal 46 dan ISO 27001 dalam format PDF bertanda tangan digital.
- Fase 4 – Q4 2027 | Multi-Tenant MSSP & Enterprise RBAC: arsitektur multi-penyewa dengan kontrol akses berbasis peran Tier-1, Tier-2, dan Manager.
- Fase 5 – 2028 | Adaptive Autonomous Honeypot Deception: sistem umpan tiruan untuk mempelajari taktik penyerang tanpa membahayakan data inti.

9. TAUTAN PENTING (LAMPIRAN)

Sebagai bahan verifikasi dan evaluasi menyeluruh Dewan Juri GTNIC 2026, berikut adalah tautan proyek kami:

• **Tautan Sistem / Prototype Live:** https://gtnic-hackwitgoh.vercel.app/ (Aktif 24/7 di jaringan Vercel Edge dan dapat diuji langsung oleh Dewan Juri).

• **Tautan Lingkungan Lab Serangan (OWASP Juice Shop):** https://juice.flummox.cloud/ (Lab aplikasi web target yang terintegrasi langsung dengan sensor reverse proxy).

• **Tautan Repositori / Dokumentasi Lengkap:** https://github.com/Greshen-Chin/GTNIC_AI_AGENT

• **Tautan Video Demo YouTube:** [Tautan Video Demo YouTube (Mode Publik atau Unlisted)]

DAFTAR PUSTAKA

1. Riset: Dalam Sedetik, 16 Serangan Siber Hantam Indonesia
2. IBM Report: Escalating Data Breach Disruption Pushes Costs to New Highs
3. ISC2. (2024). 2024 ISC2 Cybersecurity Workforce Study.
4. Updates - April 2024 | MITRE ATT&CK
5. OWASP Top 10:2025
6. UU No. 27 Tahun 2022 tentang Pelindungan Data Pribadi - JDIH BPK
7. BSSN Identifikasi Pusat Data Nasional Sementara Diserang Ransomware
8. [2210.03629] ReAct: Synergizing Reasoning and Acting in Language Models
9. Siaran Pers [NP] tentang Percepat Pemulihan, Kominfo BSSN dan Telkom Operasikan Server Baru Pengganti